

DailyMealBox — Amendment v2 Extra: status AFTER this work

Date: 2 October 2026
Branch: `claude/trusting-rubin-xzrkpf`
Spec: `DailyMealBox_Amendment__v2_Extra.docx`: Gaps A-Z, Addenda AA-AL, controls ACM-131 → ACM-183
Before: see `Amendment_v2_Extra_Audit_BEFORE.md` (2 partial, 36 missing; the 30 existing admin toggles were not read by anything)

How the Android SOP was mapped to this web-app codebase

SOP (Android)	Built here (web apps wrapped for Android)
Firebase Remote Config	Server-held Admin Controls (ACM-131 → ACM-183, 54 controls, platform value + per-city overrides). Public <code>GET /api/v1/dmb/config?zoneId=</code> with ETag. Every app re-reads it every 5 minutes and when it regains focus, so a change reaches open apps within 5 minutes with no app release.
OTA / app update	Not needed: a web deploy updates every app immediately.
FCM push	The existing web-push + in-app notifications + email, with per-type customer preferences (Gap W).
Google Drive (documents)	Cloudinary (existing media store), see open item 2 below.
On-device prices	Server-authoritative quote (<code>POST /dmb/payments/quote</code>). Checkout sends the total the customer saw, and the server refuses a stale price (409 <code>PRICE_CHANGED</code>).
Android device timezone	One platform timezone (<code>PLATFORM_TIMEZONE</code> , default Europe/Warsaw) for cut-offs, slots, shifts and jobs.
WorkManager / cron	Cluster-safe job runner in the API (16 jobs, Admin → Scheduled Jobs, each can be run on demand).

Status per gap

Legend:  done and verified ·  done with a documented deviation

Gap	Title	Status	What the apps do now
A	Dynamic delivery slots		Slot lifecycle draft → active → deactivating with a 14-day grace, fallback slot, affected subscribers flagged and asked to pick a new slot (banner + screen). Custom days (ACM-146), per-day slots (ACM-147), max slots per day (ACM-148).
B	Driver attendance		Slot times in platform time; ACM-152; City Manager alerts; fleet-partner filter; minimum-guarantee shifts in the admin attendance

Gap	Title	Status	What the apps do now
			page.
C	Annual plan	✓	Admin switch + discount; shown only when on; the quote shows the annual disclosure.
D	Discounted trial	✓	One trial per customer, price and length set by admin, shown in the quote.
E	Live stock	✓	Vendor stock per meal, "prepared" counts, low-stock job and alerts; admin stock report.
F	Bad-debt report	✓	Daily check; admin page with export.
G	Business holidays	✓	Polish holidays imported each year as <i>pending</i> for City Manager review; confirmed holidays skip deliveries and extend subscriptions; customers notified.
H	Google Analytics 4	✓	Opt-in consent banner (Consent Mode). Events <code>page_view</code> , <code>checkout_began</code> , <code>slot_selected</code> , <code>subscription_started</code> . Measurement ID set in Admin → Integrations.
I	Mailchimp	✓	Daily sync of opted-in customers only, in segments active / churned / trial. Marketing consent is timestamped.
J	WhatsApp invoices	✓	Customer chooses email / WhatsApp / both (ACM-156); queued sends with retry job; Twilio or 360dialog.
K	Zone delivery pricing	✓	Per-zone delivery fee set by admin, used by the server quote.
L	Fortnightly plan	✓	Every-other-week deliveries, billed per 2 weeks (ACM-151).
M	Pre-order launches	✓	Vendor marks a new dish as pre-order with launch and cut-off dates; customers reserve and are charged on launch day (job at 00:01).
N	Data encryption	●	See Security_Architecture_v1.md/.pdf . HTTPS enforcement + HSTS; AES-256-GCM on addresses, WhatsApp numbers, all bank details, driver ID numbers and integration secrets, with key rotation; live admin Security page. Deviation: customer phone/email still plaintext (login identifiers, needs your approval for the blind-index approach); driver document <i>images</i> still on public Cloudinary URLs.
O	Visibility controls	✓	ACM-131 → 145 as an admin matrix. Enforced server-side: hidden fields are removed from API responses. EU-locked items cannot be hidden.
P	Failed delivery / pantry return	✓	Driver "Cannot deliver" takes a real photo, reason and what happened to the box; Pantry "returned to shop" flows into the vendor's returns list and an admin report with CSV.
Q	Custom delivery days	✓	Customer picks days (ACM-146).

Gap	Title	Status	What the apps do now
R	Split ratings	✓	Food → vendor score, delivery → driver score (ACM-159); vendor replies shown to the customer.
S	Upgrade / downgrade / switch / add slot	✓	Preview with proration, then apply; several subscriptions per customer.
T	Vendor review responses	✓	Vendor replies; admin moderation.
U	Address zone validation	✓	Out-of-zone addresses refused (422) with the nearest zone suggested; the attempt is logged for expansion demand . A subscription whose address moves out of the maker's zone asks the customer to switch maker.
V	Multiple addresses	✓	Address book (Home, Office + named); deliver a single day to another saved address.
W	Notification preferences	✓	Per-type switches; critical types locked on.
X	Zone-filtered plans	✓	Plans list shows only makers serving the customer's zone.
Y	Customer segments	✓	Admin segments with drill-down.
Z	Shift confirmation	✓	24 h reminder; "Can't make it" until 2 h before; holiday handling.
AA	Two-track home cook	✓	Track 1 (unregistered) / Track 2 (business or Kitchen Partner); kitchen photos, Sanepid upload with grace period; Track 1 cooks who haven't signed the current cook agreement are hidden from customers and blocked from order actions.
AB	Track-1 settlements	✓	Monthly statements (job on the 1st), earnings vs the legal limit, threshold warnings.
AC	Legal CMS + re-acceptance	✓	Versioned documents per language; publishing a new version forces re-acceptance in every app (blocking dialog).
AD	Preferred fleet partner	✓	Vendor requests, admin approves and assigns.
AE	10-day menu preview	✓	Calendar "Upcoming days" view (ACM-171 sets the number of days).
AF	Family Box	✓	Several members, each with their own meal and slot; family discount.
AG	Select (single meal)	✓	One-time orders with a "subscribe?" prompt after delivery.

Gap	Title	Status	What the apps do now
AH	Medical specialisms	✓	Hashimoto, pregnancy, low-GI, menopause: vendor applies, admin approves with expiry; medical plan categories need an approved specialism.
AI	Eco packaging badge	✓	Vendor claims, admin verifies, customer filter.
AJ	Weekend delivery filter	✓	ACM-177; vendor delivery days; customer filter.
AK	Smart Rotation	✓	Rotate up to N makers (ACM settings), colour per maker in the calendar, edit rotation for next cycle.
AL	Hot/Cold label	✓	Required to publish (ACM-183). Cold meals need reheating instructions (≤150 characters). Driver route shows a cold-bag notice.

All customer, vendor and driver strings are translated into **Polish, German, Russian and Ukrainian** (100% seed coverage). Admin pages are English, as before.

How it was verified

Check	Result
Backend automated tests (9 suites)	129 / 129 pass: i18n 23, payments 46, plan pricing 5, email 7, subscription emails 3, attendance 15, subscription engine 18, field encryption 7, delivery ownership 5
Live end-to-end API run on a fresh database (<code>smoke.mjs</code>)	65 / 65 pass: customer, vendor, driver and admin flows over HTTP
Browser walkthrough (Chromium, real UI against the API)	53 / 53 screens load with no runtime error and no failed API call: 13 customer, 14 vendor, 3 driver, 23 admin
Interactive browser flows	New customer: accept terms → browse → subscribe sheet → server quote → checkout → pay → subscription active . Vendor: add meal, Hot/Cold rule enforced → saved. Admin: switch a control → public config changes at once.
Frontend production build (<code>vite build</code>)	passes
i18n verifier / catalog / seed check	0 problems / up to date / valid

Bugs found and fixed while verifying (this session)

1. Zone and zone-to-city caches were never cleared when an admin created, edited or deleted a zone or city. New zones weren't recognised for up to a minute, and addresses

could be assigned to a deleted zone.

2. Every subscription showed "your maker doesn't deliver to your new address" (an object was tested for truthiness).
3. Customer home told subscribers with a delivery later than tomorrow "No upcoming deliveries" and offered "Start your meal plan". It now shows the real next delivery.
4. Driver "My Shifts" listed upcoming shifts newest first.
5. Vendor dashboard showed a hard-coded date (22 May 2026).
6. Vendor app showed server errors with a green success tick.
7. New meals were saved with the city `indore` when the vendor app didn't know the city. The server now uses the vendor's city or its zone's city.
8. **Security:** any driver could mark any order *delivered* via the photo endpoint (including another driver's box, or a failed one), which also finalises the payment ledger. Now only the driver carrying it, and only once.
9. **Security:** any driver could report any not-yet-collected box as failed. Same ownership rule now.
10. **Encryption key rotation would have blanked data.** Values were tagged with a fixed key label, so after rotating the key, old values failed to decrypt and read as empty. Values now carry a key fingerprint, every configured key is tried, and the start-up migration re-encrypts to the new key. Test added; it fails on the old code.
11. Encrypted fields skipped `trim/case` options. The plugin now applies them before encrypting.
12. Admin security page showed a missing `API_PUBLIC_URL` as OK. Without it, invoice emails carry no PDF link.

What is not done, and what you need to decide or do

Decisions for DailyMealBox

1. **Phone and email encryption (Gap N).** Proposed: encrypted value + keyed blind index for login and lookup; admin search becomes exact-match. About 3-4 days. Details in Security Architecture §4.4.
2. **Driver document images (Gap N).** Move to Cloudinary authenticated delivery with 1-hour signed links (admin and driver only) and migrate existing files. Needs the production Cloudinary account to test. Security Architecture §6.2.

Before production

Setting	Why
<code>NODE_ENV=production</code>	Turns on HTTPS enforcement and HSTS
<code>PII_ENCRYPTION_KEY</code> (32 random bytes, <code>openssl rand -base64 32</code>), with an offline backup	Field encryption. Without it a development key is used.
<code>INVOICE_LINK_SECRET</code> , <code>API_PUBLIC_URL=https://...</code>	Signed invoice PDF links in emails
<code>PLATFORM_TIMEZONE=Europe/Warsaw</code> (default)	Cut-offs, slots, shifts, jobs

Setting	Why
Payment gateway keys (Przelewy24 / Stripe)	Real payments. The development "Test payment" mode is refused automatically when <code>NODE_ENV=production</code> .
SMTP (<code>EMAIL_HOST</code> , <code>EMAIL_USER</code> , <code>EMAIL_PASS</code>)	Invoices, receipts, notices
Optional: <code>MAILCHIMP_API_KEY</code> / <code>MAILCHIMP_AUDIENCE_ID</code> , <code>TWILIO_*</code> or <code>D360_*</code>	Or enter them in Admin → Integrations, where they are stored encrypted
TLS 1.3-only on the load balancer; MongoDB Atlas encryption at rest confirmed in writing	Security Architecture §8

Follow-ups outside this amendment (pre-existing)

- `/api/v1/uploads/*` accept files without a login. Sign-up flows use them, so adding auth needs those flows traced first.
- The admin "Backend disconnected" banner in local development comes from the dev proxy not forwarding WebSockets. It doesn't happen when the API and apps share an origin.

Re-running the checks

```
# backend tests (local mongod on 127.0.0.1:27017)
cd Backend
for s in i18n payments plan-pricing email subscription-emails attendance \
    subscription-engine field-encryption failed-delivery; do
    npm run test:$s
done
# frontend
cd Frontend && npx vite build && npm run i18n:check && npm run i18n:test
```